

Práticas eficazes de gestão de riscos incluem a identificação, a avaliação, a mitigação e o monitoramento sistemáticos dos riscos organizacionais. As auditorias fornecem uma avaliação independente e objetiva dos processos, controles e conformidade, garantindo o cumprimento dos padrões e identificando lacunas que representam riscos. Por outro lado, as avaliações ajudam a estimar a eficácia das estratégias de gestão de riscos, identificar possíveis vulnerabilidades e priorizar os esforços de mitigação. Ao associar auditorias e avaliações, as organizações podem ter uma compreensão abrangente dos riscos, implementar controles apropriados e monitorar e adaptar continuamente suas estratégias de gestão de riscos para se proteger contra possíveis ameaças. Essas práticas são essenciais para manter operações de segurança proativas e resilientes e garantir a conformidade com os mandatos legais.

Nesta lição, você vai fazer o seguinte:

- Explicar processos e conceitos de gestão de riscos.
- Explicar os conceitos da análise de impacto nos negócios.
- Compreender diversas respostas a riscos.
- Aprender sobre avaliações de fornecedores e práticas de gerenciamento.
- Explorar os conceitos de avaliação interna e externa.
- Conhecer os diferentes métodos de teste de penetração.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A gestão de riscos envolve identificar possíveis problemas, avaliar seu impacto potencial na organização e implementar controles para mitigá-los. Os principais conceitos incluem a identificação de riscos, a avaliação de risco, a mitigação e o monitoramento. O apetite e a tolerância ao risco são importantes para determinar o nível de risco aceitável para uma organização. Métodos como avaliações de riscos ad hoc, recorrentes, únicas ou contínuas ajudam as organizações a compreender seus riscos com precisão. Em última análise, uma gestão de riscos eficaz ajuda a proteger os ativos de informação da organização, manter a conformidade regulamentar e contribuir para os objetivos estratégicos.

Objetivos abordados no exame:

- 5.2 Explicar os elementos do processo de gerenciamento de riscos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A [\[\[identificação de riscos\]\]](#) é fundamental para a gestão de riscos de cibersegurança. Envolve o reconhecimento de riscos técnicos, como ataques de malware, tentativas de phishing, ameaças internas, falhas de equipamentos e vulnerabilidades de software, e riscos não técnicos, como políticas ou treinamento inadequados. Os métodos de identificação de riscos incluem avaliações de vulnerabilidade, testes de penetração, auditorias de segurança, threat intelligence, entre outros. A identificação de riscos é a base para as práticas de avaliação e gestão de riscos. Processos eficazes de identificação de riscos permitem que as organizações tomem decisões fundamentadas em relação à alocação de recursos, estratégias de mitigação de riscos e práticas gerais de gestão de riscos.

Avaliação de riscos

A [\[avaliação de riscos\]](#) é um componente central de um programa de cibersegurança, responsável por analisar os riscos previamente identificados para determinar seu impacto potencial na organização. As metodologias de avaliação de riscos incluem ad hoc, recorrentes, únicas ou contínuas. As avaliações ad hoc são realizadas conforme necessário, geralmente em resposta a incidentes específicos, como a descoberta de uma nova vulnerabilidade de dia zero ativamente explorada ou mudanças relativas ao ambiente, como atualizações do sistema. As avaliações únicas são abrangentes e realizadas em um momento específico, geralmente durante a implementação de um novo sistema (ou processo) ou para obter uma avaliação independente da maturidade operacional de uma organização. As avaliações recorrentes são programadas em intervalos regulares, como a cada ano, trimestre ou mês, e podem incluir auditorias, verificações de conformidade, varreduras de vulnerabilidade e outros tipos de avaliação. As avaliações contínuas avaliam constantemente os riscos com o suporte de ferramentas especializadas que produzem dados em tempo real, como plataformas de varredura de vulnerabilidades baseadas em agentes e sistemas de detecção de intrusão. Geralmente, são associados diferentes métodos de avaliação para garantir a identificação e a gestão eficazes dos riscos.

Figura 1. A avaliação quantitativa de riscos busca atribuir valores concretos a cada fator de risco



Imagem © 123RF.com.

Análise de Riscos vs. Avaliação de riscos

A [[análise de riscos]] descreve o processo de identificação e avaliação dos riscos potenciais, bem como das características que os definem. Seu objetivo é entender a natureza e o escopo dos riscos examinando suas causas, consequências e preocupações.

A avaliação de riscos é uma abordagem sistemática projetada para estimar os níveis potenciais de risco e sua relevância através da interpretação dos dados coletados durante a análise de risco. Ela considera a probabilidade de um evento ocorrer e a gravidade de suas consequências. Também pode envolver a priorização de riscos com base em seu impacto potencial e a definição de estratégias de gestão de riscos.

Análise quantitativa

A [[análise quantitativa de riscos]] busca atribuir valores concretos a cada fator de risco.

- [[Expectativa de Perda Única (SLE)]]: A quantia que seria perdida em uma única ocorrência do fator de risco. É determinado multiplicando o valor do ativo por um fator de exposição (Exposure Factor, EF). EF é a porcentagem do valor do ativo que seria perdida. Por exemplo, pode ser determinado que um tornado danificaria 40% de um edifício. Nesse caso, o fator de exposição é de 40% porque apenas parte do ativo é perdida. Se o valor do edifício for de US\$ 200 mil, a SLE desse evento é de $200.000 \times 0,4$, ou US\$ 80.000.
- [[Expectativa de Perda Anualizada (ALE)]]: O valor que seria perdido ao longo de um ano. Esse valor é determinado multiplicando-se a SLE pela taxa anualizada de ocorrência (ARO). A ARO é o número de vezes que um evento ocorre em um ano. No nosso exemplo anterior (muito simplificado), se for previsto que um tornado causará um impacto duas vezes por ano, então a ARO será simplesmente "2". A ALE é o custo do evento (SLE) multiplicado pelo número de ocorrências em um ano. No exemplo do tornado, a SLE é de US\$ 80.000 e a ARO é de 2, portanto, a ALE é de US\$ 160.000. Este número é útil ao considerar diferentes maneiras de proteger o edifício de tornados. Sabendo que os tornados terão um custo médio de US\$ 160.000 por ano, esse valor pode ser usado como comparação ao considerar o custo de várias proteções.

É importante saber que o valor de um ativo não se refere apenas ao seu valor material. As outras duas principais considerações são os custos diretos associados ao ativo que está sendo comprometido (tempo de inatividade) e os custos consequentes para os ativos intangíveis, como a reputação da empresa. Por exemplo, um servidor pode ter um custo de material de algumas centenas de dólares. Se o servidor for furtado, os custos decorrentes de não poder fazer negócios até que ele seja recuperado ou substituído podem chegar a milhares de dólares. Além disso, o período de interrupção, quando não é possível receber ou atender os pedidos, pode levar os clientes a buscar outros fornecedores, possivelmente resultando na perda de milhares de vendas e de fundo de comércio.

O valor da análise quantitativa está em sua capacidade de desenvolver números tangíveis que refletem dinheiro real. A análise quantitativa ajuda a justificar os custos de vários controles. Quando os analistas conseguem associar a economia de custos a um controle, é fácil justificar sua despesa. Por exemplo, é fácil justificar o dinheiro gasto em um balanceador de carga para eliminar as perdas causadas pelo tempo de inatividade do site que, por si só, excederam o custo de um balanceador de carga. Infelizmente, essas associações claras e diretas não são comuns!

O problema com a avaliação quantitativa de riscos é que o processo de determinação e atribuição desses valores é complexo e demorado. Também é difícil determinar a precisão dos valores atribuídos sem dados históricos (muitas vezes, é preciso se basear em suposições subjetivas). No entanto, com o tempo e a experiência, essa abordagem pode produzir uma descrição detalhada e sofisticada dos ativos e riscos e fornecer uma base sólida para justificar e priorizar os gastos com segurança.

Análise qualitativa

A [[análise qualitativa de riscos]] é um método utilizado na gestão de riscos para avaliar riscos com base em julgamento subjetivo e fatores qualitativos, em vez de dados numéricos precisos. Seu objetivo é proporcionar uma compreensão qualitativa dos riscos, o impacto potencial e a probabilidade de ocorrência. Muitas vezes referida como “análise de riscos por meio de palavras, não números”, essa abordagem ajuda a identificar e priorizar riscos intangíveis.

Um dos benefícios da análise qualitativa de riscos é sua simplicidade e facilidade de uso. Não é preciso cálculos matemáticos complexos ou uma extensa coleta de dados, o que torna essa abordagem mais acessível. Ela permite que as organizações façam uma rápida avaliação inicial dos riscos para identificar e se concentrar nos problemas mais significativos. A análise qualitativa enquadra os riscos considerando suas causas, consequências e possíveis interdependências para melhorar a comunicação dos riscos e a tomada de decisões relativas a eles.

A análise qualitativa de riscos apresenta algumas limitações. Ela é subjetiva e depende muito do discernimento de especialistas, o que muitas vezes resulta em vieses e inconsistências quando as opiniões dos especialistas divergem. A falta de dados numéricos na análise qualitativa pode dificultar a comunicação dos riscos às partes interessadas que preferem informações quantitativas. Apesar dessas limitações, a análise qualitativa de riscos é importante, pois fornece uma descrição simplificada dos riscos e pode ajudar a chamar rapidamente a atenção para problemas significativos.

Risco inerente

O resultado de uma análise quantitativa ou qualitativa é uma medida do risco inerente. Risco inerente é o nível de risco existente antes de qualquer tipo de mitigação ser aplicada.

Em teoria, controles de segurança ou medidas preventivas poderiam ser introduzidos para resolver todos os fatores de risco. No entanto, os controles de segurança podem ser caros, tornando necessário equilibrar o custo dos controles e o custo associado ao risco. Não é possível eliminar os riscos. Em vez disso, busca-se mitigar os fatores de risco até que a organização esteja exposta apenas a um nível de risco tolerável. O estado geral da gestão de riscos é denominado postura de risco. A postura de risco mostra quais opções de resposta ao risco podem ser identificadas e priorizadas. Por exemplo, uma organização pode identificar as seguintes prioridades:

- Requisitos regulamentares para implantar controles de segurança e realizar ações demonstráveis para reduzir o risco. Alguns exemplos de legislação e regulamentação que exigem controles de risco são: SOX, HIPAA, Gramm-Leach-Bliley, Homeland Security Act, regulamentos do PCI DSS e várias medidas de proteção de dados pessoais.
- Ativos de alto valor, independentemente da probabilidade da(s) ameaça(s).
- Ameaças com alta probabilidade (ou seja, ARO elevada).
- Procedimentos, equipamentos ou softwares que aumentam a probabilidade de ameaças (por exemplo, aplicativos legados, falta de treinamento do usuário, versões antigas de software, software não corrigido, execução de serviços desnecessários, não ter procedimentos de auditoria em vigor, etc.).

Mapa de calor (heat map)

Outra abordagem simples é o mapa de calor ou matriz de impacto com classificação por cores. Para cada risco, é atribuída uma cor (vermelho, amarelo ou verde) a cada coluna para representar sua gravidade, sua probabilidade, custo das medidas de controle e assim por diante. É uma abordagem bastante simples, mas que oferece uma visão imediata de onde concentrar os esforços para aumentar a segurança.

Figura 2. Matriz de impacto com indicadores vermelho, amarelo e verde.

	Risco	Impacto	ARO	Custo dos controles	Risco
Clientes legados do Windows		!	✗	!	✗
Equipe não treinada		✓	!	✓	!
Antivírus desatualizado		!	✗	!	✗
	Descrição				

Os dados na matriz são os seguintes:

Legacy Windows Clients: Impacto: indicador amarelo ARO: indicador vermelho Custo dos controles: indicador amarelo Risco geral: indicador vermelho

Untrained Staff: Impacto: indicador verde ARO: indicador amarelo Custo dos controles: indicador verde Risco geral: indicador amarelo

No Antivirus Software: Impacto: indicador amarelo ARO: indicador vermelho Custo dos controles: indicador amarelo Risco geral: indicador vermelho

A FIPS 199 aborda como aplicar categorizações de segurança (SC) a sistemas de informação com base no impacto que uma violação de confidencialidade, integridade ou disponibilidade teria para a organização como um todo. Os possíveis impactos podem ser classificados da seguinte forma:

- **Baixo:** danos ou perdas menores a um ativo ou perda de desempenho (embora as funções essenciais permaneçam operacionais).
- **Moderado:** danos ou perdas significativas a ativos ou perda de desempenho.
- **Alto:** grandes danos ou perdas, ou incapacidade de executar uma ou mais funções essenciais.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As estratégias de gestão de riscos definem abordagens proativas e sistemáticas para identificar, avaliar, priorizar e mitigar riscos com o objetivo de minimizar seus impactos negativos.

A [[mitigação de riscos (ou remediação)]] é o processo geral de reduzir a exposição a fatores de risco ou os efeitos decorrentes desses riscos. Uma contramedida que reduz a exposição a uma ameaça ou vulnerabilidade caracteriza a [[dissuasão (ou redução) de riscos]]. A redução de riscos refere-se a controles que podem diminuir as chances de um incidente de risco acontecer ou atenuar os custos caso aconteçam (ou, talvez, ambos). Por exemplo, se a possibilidade de um incêndio for uma ameaça significativa, uma política que controle rigorosamente o uso de materiais inflamáveis no local reduz a probabilidade, enquanto um sistema de alarmes e sprinklers reduz o impacto ao conter o incidente limitando-o a uma área reduzida. Outro exemplo é o backup de dados fora do local, o que possibilita a recuperação caso os servidores sejam destruídos por um incêndio.

A [[evitação]] significa interromper a atividade que está gerando o risco. Por exemplo, digamos que uma empresa esteja vendendo um aplicativo para gestão de estoque que desenvolveu internamente. Durante o processo de venda, ela descobre que o aplicativo possui inúmeras vulnerabilidades de segurança que geram reclamações e ameaças de ações judiciais. A empresa pode decidir que o custo para manter a segurança do software não vale a receita que ele gera e seu desenvolvimento. A evasão (ou evitamento) poucas vezes será uma opção convincente.

Transferência de risco

[[Transferência (ou compartilhamento)]] significa atribuir o risco a uma terceira parte, como uma seguradora. Seguros específicos para segurança cibernética ou com cobertura de responsabilidade cibernética protegem contra multas e responsabilidades legais decorrentes de ataques e violações de dados.

Nota:

Observe que, nesse caso, é relativamente simples transferir os riscos óbvios, mas os riscos à reputação da empresa permanecem. Se os dados do cartão de crédito de um cliente forem roubados porque seu aplicativo de e-commerce não é seguro, ele não vai querer saber se o responsável nominal pela segurança é você ou um terceiro. Também é improvável que as responsabilidades legais sejam completamente transferidas dessa maneira. Por exemplo, os termos do seguro provavelmente exigirão que as práticas recomendadas de controles de risco tenham sido implementadas.

Não é possível eliminar os riscos por completo, portanto, um dos principais objetivos de fazer a sua gestão é determinar um nível adequado de risco admissível. O conceito de “risco aceitável” varia bastante entre as organizações e depende do setor de atuação, do estilo de liderança, do ambiente legal e de outros fatores.

Aceitação de Risco

A [aceitação de risco] (ou tolerância) significa que não são implementadas contramedidas, pois o nível de risco não justifica tal ação.

Uma exceção de risco descreve uma situação em que um risco não pode ser mitigado usando práticas padrão de gestão de riscos ou dentro de um prazo especificado, devido a condições financeiras, técnicas ou operacionais. Uma exceção de risco reconhece formalmente o risco e busca identificar controles de mitigação alternativos, se possível. As partes interessadas relevantes, como gestores de risco ou executivos seniores, devem aprovar todas as exceções de risco. Elas devem ser temporárias e reavaliadas a intervalos estabelecidos para verificar se os níveis de risco mudaram ou se a exceção pode ser removida.

Uma [isenção de risco] é uma condição em que o risco pode permanecer sem mitigação, geralmente devido a uma decisão estratégica de negócios. As isenções de risco costumam estar relacionadas a situações em que o custo de mitigação é maior do que os possíveis danos ou que o risco pode levar a benefícios estratégicos significativos quando é aceito. Assim como as exceções de risco, as isenções devem ser formalmente documentadas e aprovadas por gestores de risco ou executivos seniores e reavaliadas periodicamente de acordo com um cronograma estabelecido.

Figura 1. As quatro respostas aos riscos são: evitar, aceitar, mitigar e transferir



Risco residual e apetite ao risco

Enquanto o risco inerente é o risco existente antes da mitigação, o [[risco residual]] corresponde à probabilidade e ao impacto restantes após a aplicação de medidas específicas de mitigação, transferência ou aceitação. O apetite ao risco é uma avaliação estratégica do nível tolerável de risco residual. Ele é, por princípio, abrangente. Enquanto a aceitação de riscos se limita a um único sistema, o apetite ao risco abrange todo um projeto ou instituição. O apetite ao risco é limitado pela regulamentação e conformidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O [[gerenciamento]] de riscos é o processo de identificar, avaliar e mitigar vulnerabilidades e ameaças às funções essenciais que uma empresa deve desempenhar para atender os clientes. Esse processo pode ser realizado em cinco fases:

1. **Identificar as funções essenciais:** a mitigação do risco pode envolver grandes despesas, por isso é importante concentrar os esforços.

Para ser eficaz, a gestão de riscos deve se concentrar nas funções essenciais que, se não forem realizadas, poderão levar ao fracasso do negócio. Parte desse processo envolve a identificação de sistemas e ativos críticos que dão suporte a essas funções.

2. **Identificar vulnerabilidades:** para cada função ou fluxo de trabalho (começando pelo mais crítico), analise sistemas e ativos para descobrir e listar quaisquer vulnerabilidades ou fragilidades às quais possam estar suscetíveis.
3. **Identificar ameaças:** para cada função ou fluxo de trabalho, identifique as fontes e autores de ameaças que podem tirar proveito, explorar ou desencadear acidentalmente vulnerabilidades.
4. **Analisar os impactos no negócio:** para avaliar o risco, são considerados fatores como a probabilidade de uma ameaça transformar uma vulnerabilidade em um incidente de segurança e o impacto desse incidente em sistemas críticos. Existem métodos quantitativos e qualitativos de análise de impactos e probabilidade.
5. **Identificar a resposta ao risco:** para cada risco, identifique possíveis contramedidas e avalie o custo da implantação de controles de segurança adicionais. A maioria dos riscos requer alguma forma de mitigação, mas pode haver outros tipos de resposta mais apropriados para determinados tipos e níveis de riscos.

Para cada processo de negócios e ameaça, você deve avaliar o grau de risco existente. O cálculo do risco é complexo, mas as duas principais variáveis são probabilidade e impacto:

- [[Probabilidade]] é frequentemente utilizada em análises qualitativas para descrever, de forma subjetiva, a chance de ocorrência de um evento de risco. Geralmente é expressa com os indicadores “baixa”, “média” e “alta” ou com uma escala de 1 a 5.
- Probabilidade é uma medida quantitativa normalmente expressa como um valor numérico entre 0 e 1 ou em porcentagem. A probabilidade visa medir com precisão a chance de um evento de risco ocorrer com base em métodos estatísticos.
- [[Impacto]] é a gravidade do risco caso ele se concretize como um incidente de segurança. Pode ser determinado por fatores como o valor do ativo ou o custo da interrupção caso o ativo seja comprometido.

Além de complexa, a gestão de riscos é tratada de formas muito diferentes em empresas e instituições de portes diversos e com diferentes requisitos regulamentares e de conformidade. A maioria das empresas implanta políticas e procedimentos de [[gestão de riscos corporativos (ERM)]], com base em frameworks como o Risk Management Framework (RMF) do NIST ou a ISO 31K. Esses requisitos de conformidade legislativa e de enquadramento geralmente são formalizados em uma autoavaliação de risco e controle (Risk and Control Self-Assessment, RCSA). Uma organização também pode contratar uma entidade externa para liderar o processo, sendo este então referido como avaliação de risco e controle (Risk and Control Assessment, RCA).

Uma RCSA é um processo interno em que as partes interessadas identificam riscos e avaliam a eficácia dos controles na mitigação desses riscos. Geralmente, as RCSAs são realizadas por meio de questionários e workshops com gerentes de departamento. O resultado de uma RCSA é um relatório. Dispor de relatórios de RCSA atuais é fundamental para o processo de auditoria externa.

Registros de riscos

Um [[registro de riscos]] é um documento que apresenta os resultados das avaliações de riscos de forma compreensível e inclui informações sobre os riscos, sua gravidade, o responsável associado ao risco e todas as estratégias de mitigação identificadas. O registro pode incluir uma [[matriz de risco do tipo heat map]] (apresentada anteriormente), com colunas para classificações de impacto e probabilidade, data de identificação, descrição, contramedidas, responsável/rota de escalonamento e status.

Os registros de riscos também costumam ser representados como gráficos de dispersão, em que o impacto e a probabilidade formam os eixos e cada ponto do gráfico possui uma legenda com informações sobre a natureza do risco. Um registro de riscos deve ser compartilhado entre os stakeholders (executivos, gerentes de departamento e técnicos seniores) para que compreendam os riscos associados aos fluxos de trabalho sob sua gestão.

Limite de risco

O limite de risco define os limites ou níveis de risco aceitáveis para uma organização. Dentro dessa delimitação, os riscos são considerados aceitáveis e administráveis. Os limites de risco se baseiam em vários fatores, como requisitos regulamentares, objetivos organizacionais, expectativas das partes interessadas e o apetite ao risco da organização, para estabelecer diretrizes claras para a tomada de decisões. As organizações geralmente definem limites de risco diferentes para diferentes tipos de risco com base em seu impacto e criticidade potenciais.

Indicadores-chave de risco

[[Indicadores-chave de risco (KRIs)]] são indicadores preditivos críticos usados pelas organizações para monitorar e prever riscos potenciais. Essas métricas fornecem um indício inicial do aumento de exposições ao risco em diferentes áreas da organização. Os KRIs avaliam o impacto potencial e a probabilidade de diversos riscos para que as equipes de liderança possam tomar medidas proativas e geri-los de forma eficaz.

O uso de KRIs está intimamente associado a registros de riscos e práticas de gestão de riscos, pois fornecem os dados necessários para avaliar a probabilidade e o impacto potencial de cada risco identificado em um registro de riscos. Por exemplo, um KRI pode identificar uma tendência de aumento no tempo de inatividade do sistema devido a problemas operacionais de TI, o que afeta as operações de negócios. Para resolver isso, os gestores de risco criam um registro de riscos com detalhes como possíveis impactos (perda de produtividade, insatisfação do cliente), etapas de mitigação (aumento de recursos de TI, melhoria da redundância do sistema) e a pessoa ou equipe responsável por gerir essas mitigações.

O [[responsável pelo risco]] refere-se ao indivíduo encarregado de gerenciar um risco específico, incluindo identificar e avaliar o risco, implementar medidas para mitigá-lo, monitorar a eficácia dessas medidas e tomar ações corretivas quando necessário. O responsável pelo risco tem um amplo conhecimento do risco e de seus possíveis impactos, assim como uma compreensão aprofundada das medidas necessárias para administrá-lo. Essa função é geralmente atribuída aos membros da equipe de liderança com autoridade para tomar decisões e capacidade de alocar recursos para mitigação de riscos. O responsável pelo risco também informa outras partes interessadas sobre o risco e seu status.

O [[apetite ao risco]] descreve o nível de risco que uma organização está disposta a aceitar. Ele é fundamental para a organização determinar quais riscos devem ser adicionados a um registro de riscos e como eles serão priorizados. Quando identificados e avaliados, os riscos são comparados com o apetite ao risco da organização. A [[tolerância ao risco]] descreve a quantidade específica de variação que uma organização está disposta a aceitar em relação aos níveis de risco medidos e ao apetite ao risco estabelecido. Se a probabilidade ou o impacto potencial de um risco ultrapassar a tolerância ao risco da organização, ele será adicionado ao registro de riscos para gestão e monitoramento apropriados. Os riscos que excedem significativamente a tolerância ao risco da organização geralmente são priorizados e tratados com mais urgência do que os outros. Por outro lado, se um risco estiver próximo ou um pouco acima do limite de tolerância, as equipes de liderança podem decidir aceitá-lo e monitorá-lo de perto.

Níveis de apetite ao risco

Nível	Descrição
Expansionista	Uma organização com apetite ao risco expansionista está disposta a assumir níveis mais altos de risco na busca por retornos elevados ou crescimento agressivo. Geralmente são organizações que operam em mercados ou setores em rápida evolução e devem assumir riscos para se manterem competitivas. Os apetites ao risco expansionistas estão associados a organizações que lançam novos produtos, entram em novos mercados ou fazem grandes aquisições corporativas.

Nível	Descrição
Conservador	Uma organização com apetite ao risco conservador prioriza a evasão (ou evitamento) dos riscos. Esse tipo de organização aborda os riscos de forma cautelosa e prioriza a preservação do caixa, a manutenção de uma boa reputação ou a garantia da conformidade regulamentar, em vez de buscar um crescimento agressivo.
Neutro	Uma organização com apetite ao risco neutro equilibra as abordagens expansionista e conservadora e está disposta a assumir riscos desde que estejam alinhados aos objetivos estratégicos e possam ser geridos de forma eficaz.

Relatório de riscos

O [[relatório de riscos]] descreve os métodos utilizados para comunicar o perfil de risco de uma organização e a eficácia de seu programa de gestão de riscos. Um relatório de riscos eficaz auxilia na tomada de decisões, evidencia as preocupações e assegura que as partes interessadas entendam os riscos da organização. O conteúdo dos relatórios de riscos deve ser relevante para o público a que se destina. Por exemplo, os relatórios criados para os membros do conselho devem ter como foco os riscos estratégicos e o apetite geral ao risco da organização. Os relatórios de riscos operacionais devem incluir detalhes específicos sobre os fatores que contribuem para o risco e são apropriados para gerentes ou funcionários técnicos. Os relatórios de riscos também devem informar claramente as recomendações de resposta ao risco, como aceitar, mitigar, transferir ou evitar o risco.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Identificação de sistemas críticos

Para promover a resiliência das funções essenciais e primárias dos negócios, é fundamental identificar os sistemas críticos. Isso envolve a compilação de um inventário dos processos do negócio e dos ativos que os sustentam. Os tipos de ativo são:

- Pessoas (funcionários, visitantes e fornecedores).
- Ativos tangíveis (edifícios, móveis, equipamentos e maquinário fabril, equipamentos de informática e telecomunicação, arquivos de dados eletrônicos e documentos em papel).
- Ativos intangíveis (ideias, reputação comercial, marca e assim por diante).
- Procedimentos (cadeias de suprimentos, procedimentos críticos, procedimentos operacionais padrão).

No caso das funções essenciais, é importante reduzir o número de dependências entre os componentes. As dependências são identificadas através de uma análise de processos de negócios (Business Process Analysis, BPA) para cada função. A BPA deve identificar os seguintes fatores:

- **Entradas:** as fontes de informações para executar a função (incluindo o impacto se estiverem atrasadas ou fora de sequência).
- **Hardware:** o servidor ou datacenter específico que executa o processamento.
- **Facilitadores:** equipe e outros recursos que dão suporte à função.
- **Saídas:** os dados ou recursos produzidos pela função.
- **Fluxo do processo:** uma descrição passo a passo de como a função é realizada.

A [[análise de impacto nos negócios (BIA)]] é um processo que auxilia as empresas a compreenderem os possíveis efeitos de interrupções em suas operações. Isso envolve identificar e avaliar o impacto de diversos cenários de ameaça não previstos nos negócios, como acidentes, emergências e desastres. Ao realizar uma BIA, as empresas podem criar, de forma proativa, estratégias de recuperação para minimizar o impacto das interrupções e garantir a resiliência operacional.

Por exemplo, se um ataque DDoS suspender um portal de e-commerce por cinco horas, a análise de impacto nos negócios poderá quantificar, com base em dados históricos, as perdas relacionadas a pedidos não feitos e clientes que trocaram permanentemente de fornecedor. A probabilidade de um ataque DDoS pode ser avaliada no âmbito ano a ano para determinar o impacto anualizado em termos de custos. Essa informação é usada para avaliar se um controle de segurança, como balanceamento de carga ou mitigação de DDoS gerenciada, vale o investimento.

Funções essenciais

Uma [[função essencial da missão (MEF)]] não pode ser adiada. Isso significa que a organização deve ser capaz de executar a função do modo mais contínuo possível. Além disso, em caso de interrupção no serviço, as funções essenciais da missão devem ser restauradas primeiro.

Nota:

As funções que dão suporte ao negócio ou a uma MEF mas que não são críticas por si só, são chamadas de funções primárias de negócios (Primary Business Functions, PBF).

A análise das funções essenciais geralmente é regida por quatro métricas principais:

- O [[tempo máximo tolerável de inatividade (MTD)]] é o maior período em que uma interrupção de uma função de negócio pode ocorrer sem causar uma falha irreversível nos negócios. Cada processo de negócios pode ter seu próprio MTD, por exemplo: um intervalo de minutos a horas para funções críticas, 24 horas para funções urgentes, sete dias para funções normais e assim por diante. Os MTDs variam de acordo com a empresa e o evento. Cada função pode ter suporte de vários sistemas e ativos. A métrica MTD define o limite máximo do tempo de recuperação que o sistema e os proprietários do ativo têm para retomar as operações. Por exemplo, uma empresa especializada em equipamentos médicos pode operar por três meses sem receber materiais de produção porque armazenou um estoque considerável. Após três meses, ela não terá materiais suficientes e talvez não consiga fabricar mais produtos, o que resultaria em falha. Nesse caso, o MTD é de três meses.

- O [[objetivo do tempo de recuperação (RTO)]] é o período após um desastre em que um sistema de TI individual pode permanecer offline. Isso representa o tempo necessário para identificar se há um problema e executar a recuperação (por exemplo, restaurar do backup ou mudar para um sistema alternativo).
- [[Tempo de recuperação do trabalho (Work Recovery Time, WRT)]]: Após a recuperação dos sistemas, pode haver trabalho adicional para reintegrar os diferentes sistemas, testar a funcionalidade geral e informar os usuários do sistema sobre quaisquer alterações ou práticas de trabalho diferentes para que a função de negócios volte a ter total suporte.

Nota:

RTO+WRT não deve exceder o MTD!

- O [[objetivo do ponto de recuperação (RPO)]] é a quantidade de perda de dados que um sistema pode suportar, medida em unidades de tempo. Ou seja, se um banco de dados for destruído por um vírus, um RPO de 24 horas significa que poderão ser recuperados dados de uma cópia de backup que foram salvos até 24 horas antes de o banco de dados ter sido infectado. O RPO é determinado identificando a perda máxima de dados aceitável para uma organização, em caso de desastre ou falha do sistema, e é estabelecido considerando fatores como requisitos de negócios, criticidade de dados e obrigações regulamentares ou contratuais. O cálculo do RPO afeta diretamente a frequência de backups de dados, os requisitos de replicação de dados, a seleção de locais de recuperação e as tecnologias que suportam failover e alta disponibilidade.

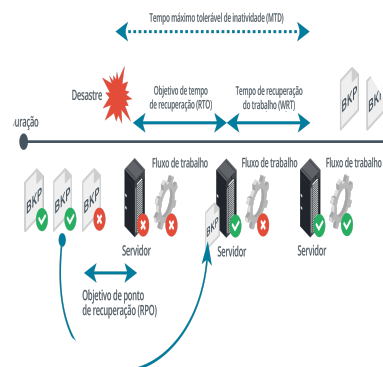


Figura 1. Métricas que controlam funções essenciais.

Imagens © 123RF.com.

Descrição

Uma seta apontando para a direita está rotulada como tempo. O tempo máximo tolerável de inatividade (MTD) é o maior período após um desastre. O recovery time objective (RTO) ocorre após o desastre e é seguido pelo work recovery time (WRT).

Por exemplo, um banco de dados de gestão de relacionamento com o cliente pode suportar a perda de algumas horas ou dias de dados, pois os funcionários geralmente conseguem se lembrar das pessoas que contataram e das conversas que tiveram durante esse período. Em contrapartida, o processamento de pedidos geralmente é mais sensível ao tempo, pois perdas de dados representam perdas de pedidos, e pode ser impossível recuperá-los ou os processos relacionados iniciados por sistemas de processamento de pedidos, como dados de contabilidade e processamento.

O MTD e o RPO ajudam a determinar quais funções de negócios são críticas e a especificar contramedidas de risco apropriadas. Por exemplo, se o seu RPO for medido em dias, um sistema simples de backup em fita será suficiente.

Contudo, se o RPO for zero ou medido em minutos ou segundos, será necessária uma solução mais cara de redundância e backup de cluster de servidores.

O tempo médio de reparo (Mean Time To Repair, MTTR) e o tempo médio entre falhas (Mean Time Between Failures, MTBF) são indicadores-chave de desempenho (Key Performance Indicators, KPIs) usados para medir a confiabilidade e a eficiência de sistemas, processos e equipamentos. Ambas as métricas são importantes para os processos de gestão de riscos, pois oferecem insights mensuráveis sobre possíveis riscos e dão suporte a estratégias de mitigação de riscos.

O MTTR e o MTBF orientam decisões sobre o design do sistema, as práticas de manutenção e os requisitos de redundância ou failover.

- O [[tempo médio entre falhas (MTBF)]] representa a vida útil estimada de um produto. O cálculo do MTBF é o tempo operacional total dividido pelo número de falhas. Por exemplo, se você tem 10 dispositivos que funcionam por 50 horas e dois deles falham, o MTBF é de 250 horas/falha $(10 \times 50) / 2$.
- O [[tempo médio de reparo (MTTR)]] é uma medida do tempo necessário para corrigir uma falha e restaurar o sistema à operação plena. Também pode ser descrito como tempo médio para substituir ou recuperar. O MTTR é calculado como o número total de horas de manutenção não planejada dividido pelo número de incidentes de falha. Esse valor médio pode ser usado para estimar se um objetivo de tempo de recuperação (RTO) pode ser alcançado.

Um MTTR mais baixo indica uma restauração mais rápida da funcionalidade, reduzindo o tempo de inatividade e possíveis interrupções nas operações. Essas informações auxiliam na alocação de recursos, na priorização das atividades de manutenção e na otimização dos processos de reparo. O MTBF identifica o tempo médio entre falhas no sistema ou no equipamento. Um MTBF mais alto sugere maior confiabilidade e intervalos mais longos entre falhas, o que pode afetar o agendamento de manutenção, a gestão de peças de reposição e o desempenho geral do sistema. Com base nos dados do MTBF, as organizações podem tomar decisões sobre estratégias de manutenção, substituição de equipamentos e investimentos para melhoria da confiabilidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A avaliação de riscos de terceiros envolve vários processos importantes que são essenciais para práticas eficazes de gestão de riscos. Esses processos incluem diligência prévia (due diligence) de fornecedores, identificação e avaliação de riscos, monitoramento contínuo e planejamento de resposta a incidentes. A diligência prévia de fornecedores envolve a avaliação e seleção de fornecedores com base em suas práticas de segurança, estabilidade financeira, conformidade regulamentar e reputação. A identificação e avaliação de riscos incluem o reconhecimento dos riscos potenciais

associados às relações com os fornecedores e a análise do seu impacto potencial nas operações, nos dados e na reputação da organização. O monitoramento contínuo garante que os fornecedores mantenham controles de segurança, cumpram as obrigações contratuais e resolvam prontamente os riscos ou vulnerabilidades identificados.

Esses processos são fundamentais nas práticas de gestão de riscos, pois ajudam as organizações a identificar, avaliar e mitigar os riscos associados a relações com terceiros. As organizações podem gerir e reduzir os riscos de forma proativa implementando processos robustos de avaliação de riscos de terceiros, protegendo os ativos, mantendo a conformidade regulamentar e promovendo um ambiente operacional seguro e protegido.

Objetivos abordados no exame:

- 5.3 Explicar os processos associados à avaliação e gestão de riscos de terceiros.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As práticas de seleção de fornecedores devem avaliar e analisar sistematicamente possíveis fornecedores para minimizar os riscos associados à terceirização ou aquisição. Esse processo normalmente envolve várias etapas, como a definição dos critérios de risco, a realização de [[due diligence]] e a seleção de fornecedores com base em seu perfil de risco. As práticas de gestão de riscos visam identificar e mitigar os riscos relacionados à estabilidade financeira, confiabilidade operacional, segurança de dados, conformidade regulamentar e reputação. O objetivo é selecionar fornecedores que estejam alinhados com a tolerância ao risco da organização e demonstrem a capacidade de gerir os riscos de forma eficaz.

Avaliação de fornecedores terceirizados

Um fornecedor terceirizado é uma pessoa ou organização externa que fornece bens, serviços ou soluções tecnológicas a outra organização, mas opera de forma independente. Os fornecedores terceirizados têm um papel significativo nas operações de negócios, pois oferecem conhecimento especializado, produtos e serviços que dão suporte ou viabilizam as capacidades próprias da organização. Podem ser desde fornecedores de tecnologia, software e serviços em nuvem até prestadores de serviço, e representam coletivamente a cadeia de suprimentos de uma organização. Os fornecedores terceirizados trazem eficiência, custo-benefício, conhecimento e inovação para as organizações, mas também apresentam riscos, pois podem ter acesso a dados confidenciais, infraestrutura ou processos críticos. A avaliação adequada e o monitoramento contínuo garantem que os fornecedores terceirizados sigam os padrões de segurança e a conformidade regulamentar e cumpram suas obrigações de proteger as operações de negócios de possíveis vulnerabilidades e interrupções.

A avaliação de fornecedores é um componente crítico das estruturas de governança, risco e conformidade (Governance, Risk, and Compliance, GRC) e tem um papel fundamental na manutenção da segurança das operações de TI e de negócios. Esse processo inclui avaliar minuciosamente as capacidades, práticas e medidas de segurança de fornecedores terceirizados antes de firmar parcerias de negócios ou conceder acesso a dados confidenciais e serviços críticos. A importância dessa avaliação se deve ao fato de que as organizações dependem cada vez mais de fornecedores externos para vários aspectos de suas operações, como soluções de tecnologia, serviços em nuvem, gerenciamento da cadeia de suprimentos e terceirização. Ao avaliar minuciosamente os fornecedores, as empresas podem garantir que seus parceiros sigam os padrões de segurança estabelecidos, cumpram os requisitos regulamentares e reduzam os possíveis riscos de forma eficaz. Estabelecer parcerias com fornecedores que tenham práticas insuficientes de segurança ou medidas inadequadas de gestão de riscos pode introduzir vulnerabilidades significativas.

Um estudo feito pelo Ponemon Institute e Bomgar identificou as seguintes estatísticas:

- As empresas permitem que, em média, 89 fornecedores acessem suas redes semanalmente.
- 69% das organizações já sofreram uma violação de dados devido a deficiências de segurança dos fornecedores.
- 65% dos entrevistados dizem que é difícil gerenciar os riscos de segurança cibernética associados a fornecedores terceirizados.
- 64% dos entrevistados disseram que sua organização se concentra mais no custo do que na segurança ao terceirizar.

<https://securitystudio.com/top-7-vendor-related-breaches-of-all-time/> (<https://securitystudio.com/top-7-vendor-related-breaches-of-all-time/>)

Avaliar os fornecedores é vital para que as empresas cumpram os regulamentos, pois esses regulamentos geralmente se aplicam aos fornecedores com os quais colaboram. Garantir que os fornecedores cumpram os regulamentos aplicáveis e os padrões do setor protege a organização contra multas e outras consequências legais.

Além disso, as avaliações de fornecedores oferecem evidências de devida diligência e verificações de conformidade, que são fundamentais durante auditorias e investigações. A avaliação do fornecedor também promove a transparência e a responsabilização. As organizações obtêm informações sobre os recursos de segurança do fornecedor avaliando minuciosamente suas práticas de segurança. Esse conhecimento embasa uma melhor avaliação de risco e uma melhor seleção de fornecedores. Além disso, as avaliações dos fornecedores criam uma estrutura para monitorar e revisar o desempenho e as práticas de segurança dos fornecedores. A avaliação contínua ajuda a garantir que os fornecedores mantenham seu compromisso com a segurança e permaneçam alinhados com a organização.

Conflito de interesses

Um [conflito de interesses] surge quando um indivíduo ou organização tem interesses ou obrigações conflitantes que podem comprometer sua capacidade de agir de forma objetiva, imparcial ou no melhor interesse de outra parte. Ao realizar avaliações de fornecedores, é vital determinar se os interesses, relacionamentos ou afiliações de um fornecedor podem influenciar sua capacidade de prover recomendações imparciais, preços justos ou oferecer serviços de forma não tendenciosa. As organizações devem identificar e abordar diligentemente possíveis conflitos de interesse, incluindo

o exame minucioso das afiliações do fornecedor, relacionamentos com concorrentes ou partes interessadas, interesses financeiros e qualquer viés potencial que possa comprometer sua integridade. Alguns exemplos de conflito de interesses incluem:

- **Interesses financeiros:** um fornecedor pode ter interesse financeiro em recomendar produtos ou serviços específicos devido a parcerias, comissões ou incentivos financeiros que influenciem suas recomendações e levem à seleção de opções que podem não atender às necessidades da organização.
- **Relações pessoais:** se um fornecedor tiver relações pessoais ou vínculos próximos com os tomadores de decisão dentro da organização, isso pode influenciar a tomada de decisões e comprometer a avaliação objetiva de outros fornecedores.
- **Relacionamentos competitivos:** um fornecedor pode ter um relacionamento comercial ou interesse competitivo com outro fornecedor que esteja sendo considerado, o que pode levar um fornecedor a priorizar seus próprios interesses ou parcerias em detrimento dos melhores interesses da organização.
- **Informações privilegiadas:** nos casos em que um fornecedor tem acesso a informações confidenciais ou privadas sobre outros fornecedores ou sobre os planos estratégicos da organização, ele pode usar essas informações para obter uma vantagem injusta ou manipular o processo de seleção.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A devida diligência, no contexto da avaliação e seleção do fornecedor, refere-se ao processo abrangente e sistemático de coletar e analisar informações sobre possíveis fornecedores para avaliar sua adequação, confiabilidade e integridade. Isso envolve a realização de uma investigação e avaliação completas dos fornecedores com base em critérios predeterminados, incluindo estabilidade financeira, reputação, recursos técnicos, práticas de segurança, conformidade regulamentar e desempenho histórico.

A devida diligência visa minimizar os riscos e embasar decisões informadas durante o processo de seleção do fornecedor, verificando a precisão das declarações do fornecedor, identificando possíveis sinais de alerta e garantindo o alinhamento com as necessidades da organização. Por meio da devida diligência ou diligência preliminar (due diligence), as organizações podem descobrir quaisquer riscos ou problemas não divulgados, entender claramente os recursos e limitações do fornecedor e avaliar o impacto potencial nas operações de negócios.

Teste de penetração: o teste de penetração avalia a postura de segurança dos fornecedores e identifica possíveis vulnerabilidades em seus sistemas, redes e aplicativos. Ao realizar testes de penetração na infraestrutura do fornecedor ou buscar evidências de que os testes de penetração foram realizados, as organizações podem obter informações sobre as vulnerabilidades que os invasores podem explorar, ajudando-as a entender os riscos potenciais associados à parceria com o fornecedor. O teste de penetração fornece uma avaliação abrangente da resiliência de segurança do

fornecedor, permitindo que as empresas tomem decisões informadas sobre sua adequação como fornecedor. Eles também melhoram o processo de avaliação do fornecedor, validando a eficácia dos controles de segurança, descobrindo fraquezas ocultas e auxiliando as práticas de gestão de riscos.

Cláusula de direito de auditoria: uma cláusula de direito de auditoria é uma disposição contratual que concede a uma organização a autoridade para realizar auditorias ou avaliações de práticas operacionais, sistemas de informação e controles de segurança dos fornecedores. A cláusula de direito de auditoria respalda as práticas de avaliação dos fornecedores ao permitir que as organizações validem e verifiquem a conformidade do fornecedor com as obrigações contratuais, os padrões de segurança e os requisitos regulamentares. Ao exercer o direito de auditar, as organizações podem obter transparência nas operações do fornecedor, identificar lacunas ou deficiências e garantir que o fornecedor mantenha o nível esperado de segurança e conformidade em todos os momentos.

Evidência de auditorias internas: ao realizar a devida diligência quanto ao fornecedor, é crucial procurar evidências de que o fornecedor tenha práticas de auditoria interna. A auditoria interna fornece uma avaliação independente e objetiva dos controles internos de uma organização, das práticas de gestão de riscos e da conformidade com as políticas e regulamentos. Ao examinar a presença e a eficácia das auditorias internas nas operações de um fornecedor, as empresas podem ganhar confiança no compromisso do fornecedor com a boa governança, a gestão de riscos e a conformidade. As evidências de auditoria interna demonstram que o fornecedor estabeleceu mecanismos para supervisão interna, avaliações periódicas e melhoria contínua de seus processos. Isso demonstra uma abordagem proativa para a identificação e mitigação de riscos e um compromisso com a segurança das operações.

Avaliações independentes: as organizações geralmente dependem de avaliações independentes como critérios cruciais de seleção de fornecedores. As avaliações independentes demandam o envolvimento de especialistas independentes para avaliar e verificar os recursos, a segurança e as práticas de conformidade do fornecedor. Essas avaliações proporcionam uma análise objetiva e imparcial dos recursos do fornecedor. Ao utilizar avaliações independentes, as organizações podem se beneficiar ao obter conhecimento especializado e boas práticas do setor quanto a avaliações de segurança que as equipes internas podem não conhecer. O uso de avaliações independentes ajuda a mitigar uma possível parcialidade, garantir avaliações completas e embasar a tomada de decisões informadas durante o processo de seleção do fornecedor. Além disso, a reavaliação periódica dos fornecedores existentes promove a melhoria contínua das práticas de segurança do fornecedor.

Análise da cadeia de suprimentos: cadeia de suprimentos refere-se à rede interconectada de entidades envolvidas na produção, distribuição e entrega de bens ou serviços, de fornecedores de matérias-primas a fabricantes, distribuidores, varejistas e, por fim, ao cliente final. É um ecossistema complexo que envolve a colaboração entre vários fornecedores em vários estágios. Os fornecedores são essenciais na cadeia de suprimentos, pois proveem bens, serviços e conhecimentos especializados que contribuem para o produto ou serviço final. Os fornecedores geralmente incluem fornecedores de matérias-primas, fabricantes, e prestadores de serviços de logística e de soluções tecnológicas. Cada fornecedor dentro da cadeia de suprimentos tem seu próprio conjunto de recursos, processos e riscos potenciais. A gestão e a avaliação desses fornecedores são cruciais para garantir o fluxo regular de materiais, minimizar interrupções, manter os padrões de qualidade e os requisitos de segurança e conformidade em toda a cadeia de suprimentos. A análise da cadeia de suprimentos avalia os riscos e vulnerabilidades associados às várias entidades (fornecedores) envolvidas em uma cadeia de suprimentos, examinando as práticas de segurança, os recursos e a confiabilidade de fornecedores individuais dentro da rede da cadeia de suprimentos e como os problemas de segurança com um

fornecedor na cadeia podem comprometer a segurança do ambiente da organização. Essas informações ajudam as organizações a identificar elos fracos, vulnerabilidades e possíveis pontos de comprometimento dentro da cadeia de suprimentos, para que possam ser resolvidos antes que causem problemas.

Nota:

A realização de visitas ao local do fornecedor oferece a oportunidade de observar e avaliar pessoalmente as instalações físicas, os processos operacionais e as práticas gerais de gestão de riscos de um fornecedor, permitindo uma avaliação mais abrangente dos riscos e vulnerabilidades potenciais.

Monitoramento de fornecedores

O monitoramento de fornecedores envolve a supervisão e avaliação contínuas dos fornecedores para garantir o cumprimento contínuo dos padrões de segurança, dos requisitos de conformidade e das obrigações contratuais. Isso pode incluir análises regulares de desempenho, avaliações periódicas e monitoramento em tempo real das atividades do fornecedor. Essa abordagem proativa permite que as organizações identifiquem e arquem prontamente com os possíveis riscos ou problemas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os acordos legais desempenham um papel vital no apoio às relações com os fornecedores, estabelecendo os direitos, responsabilidades e expectativas de ambas as partes. Os acordos legais servem como base para a relação fornecedor-cliente, proporcionando uma estrutura para a realização de negócios e para a resolução de possíveis problemas ou disputas que possam surgir.

Acordos iniciais

São necessários diferentes tipos de acordos para governar as relações com os fornecedores com base na natureza específica do contrato e nos serviços prestados. Os seguintes acordos desempenham papéis distintos na configuração das relações com os fornecedores:

- **[[Memorando de Entendimento (MOU, da sigla em inglês)]]**: um acordo não vinculativo que descreve as intenções, os objetivos compartilhados e os termos gerais de cooperação entre as partes. Os MOUs servem

como uma etapa preliminar para estabelecer um entendimento comum antes de prosseguir com um acordo mais formal.

- [[Acordo de Confidencialidade (NDA, da sigla em inglês)]]: garante a confidencialidade e a proteção das informações confidenciais compartilhadas durante o relacionamento. Um NDA é um acordo vinculativo e provavelmente será assinado juntamente de um MOU.
- [[Memorando de Acordo (MOA, da sigla em inglês)]]: um acordo formal que define os termos, condições e responsabilidades específicas das partes. Os MOAs estabelecem uma relação juridicamente vinculativa que abrange objetivos, funções, recursos e obrigações. Eles proporcionam uma estrutura confiável para a colaboração.
- [[Acordo de Parceria Empresarial (BPA, da sigla em inglês)]]: rege parcerias estratégicas de longo prazo entre organizações. Os BPAs abrangem vários objetivos, incluindo metas, acordos financeiros, processos de tomada de decisão, direitos de propriedade intelectual, confidencialidade e mecanismos de resolução de disputas. Os BPAs fornecem um meio para governar relacionamentos colaborativos e mutuamente benéficos.
- [[Acordo Mestre de Serviços (MSA, da sigla em inglês)]]: estabelece os termos e condições gerais de um contrato específico, como a provisão de recursos em nuvem ou o suporte por meio de sistemas de chamados/help desk. Um MSA inclui escopo, preços, entregas e direitos de propriedade intelectual.

Acordos detalhados

Enquanto os acordos iniciais estabelecem uma estrutura para colaboração ou prestação de serviços, outros acordos podem ser implementados para especificar os termos dos detalhes operacionais. Isso ajuda a administrar as relações com os fornecedores de forma eficaz.

- [[Acordo de Nível de Serviço (SLA, da sigla em inglês)]]: define os indicadores específicos de desempenho, padrões de qualidade e níveis de serviço esperados do fornecedor.
- [[Declaração de Trabalho (SOW, da sigla em inglês) / Ordem de Serviço (WO, da sigla em inglês)]]: detalha o escopo, os entregáveis, os prazos e as responsabilidades de um projeto ou serviço realizado pelo fornecedor. As SOWs esclarecem as tarefas do fornecedor, as expectativas da organização e as entregas acordadas. Eles são cruciais para gerir a execução do projeto e garantir o alinhamento entre o fornecedor e a organização.

Questionários

[Questionários] coletam informações dos fornecedores sobre suas práticas de segurança, controles e estratégias de gestão de riscos, auxiliando as organizações a avaliar a postura de segurança do fornecedor, identificar vulnerabilidades e analisar suas capacidades. Os questionários fornecem um meio estruturado de obter informações coerentes e uniformes sobre os fornecedores, permitindo análises e comparações de riscos mais eficazes de forma justa e sistemática. Os questionários coletam informações sobre as políticas, procedimentos e controles de segurança do fornecedor, incluindo proteção de dados, gerenciamento de acesso, resposta a incidentes e recuperação de desastres. O questionário pode abordar a conformidade de um fornecedor com regulamentos e padrões específicos do setor, como a Lei Geral de Proteção de Dados (LGPD), HIPAA, ISO 27001 ou PCI-DSS. Também pode procurar obter detalhes sobre os programas de treinamento e conscientização de segurança impostos pelo fornecedor aos funcionários e sua abordagem para a realização de avaliações e auditorias de segurança por terceiros. Além disso, o questionário pode explorar as capacidades de resposta a incidentes do fornecedor, o histórico de violações e a cobertura de seguro.

Nota:

As respostas aos questionários de gestão de risco do fornecedor devem ser validadas solicitando documentação que corrobore essas respostas, realizando visitas ou auditorias no local, realizando verificações de antecedentes, contatando referências ou clientes anteriores e utilizando serviços de verificação de terceiros para garantir a precisão e confiabilidade das respostas do fornecedor.

Regras de engajamento

As [regras de engajamento] (Rules of Engagement, ou RoE) definem os parâmetros e as expectativas para o relacionamento com fornecedores. Elas descrevem as responsabilidades, os métodos de comunicação, os mecanismos de apresentação de relatórios, os requisitos de segurança e as obrigações de conformidade que os fornecedores devem cumprir. As regras de compromisso estabelecem diretrizes claras para o comportamento, as atividades e o acesso do fornecedor a informações confidenciais. Ao definir tais limites, as organizações podem estabelecer um ambiente controlado e seguro, mitigando os riscos potenciais associados a relacionamentos com terceiros. Alguns elementos importantes incluídos em uma RoE são:

- **Funções e responsabilidades:** definem claramente as funções e responsabilidades do fornecedor e do cliente no gerenciamento de riscos, incluindo a especificação de quem é responsável por identificar, avaliar e mitigar vários tipos de riscos.
- **Requisitos de segurança:** estipulam os padrões, práticas e controles de segurança que o fornecedor deve cumprir, incluindo disposições relacionadas à proteção de dados, controles de acesso, criptografia, resposta a incidentes e avaliações regulares de segurança.
- **Obrigações de conformidade:** declaram as obrigações regulatórias e de conformidade que o fornecedor deve cumprir, garantindo que elas estejam alinhadas aos requisitos específicos do setor de atuação do cliente, incluindo de privacidade, segurança de dados e quaisquer outros regulamentos legais ou setoriais aplicáveis.
- **Relatórios e comunicação:** estabelecem protocolos para relatar em tempo hábil incidentes de segurança, violações ou riscos potenciais, incluindo a definição dos canais para relato, frequência e nível de detalhes necessários para garantir uma comunicação e gerenciamento eficazes dos riscos.
- **Gestão de mudanças:** procedimentos para fazer a gestão de mudanças ou atualizações de sistemas, processos ou serviços que possam afetar a segurança e introduzir novos riscos, incluindo processos de aprovação de mudanças, requisitos de testes e práticas de documentação.
- **Disposições contratuais:** incluem disposições relacionadas à indenização, responsabilização, seguros e direitos de rescisão em caso de violações de segurança ou descumprimento das obrigações de gestão de riscos. Essas disposições ajudam a atribuir responsabilidades e oferecem recursos legais em caso de descumprimento ou violação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Auditorias e avaliações são cruciais para manter operações confiáveis. As auditorias envolvem a avaliação sistemática de processos, controles e conformidade com os padrões, políticas e regulamentos estabelecidos. Elas garantem que as operações de uma organização se alinhem aos requisitos definidos, identificam deficiências e fornecem recomendações de melhoria.

Por outro lado, as avaliações envolvem estimar a eficácia e a eficiência de vários aspectos das operações de uma organização, como segurança cibernética, gestão de riscos e controles internos. Elas ajudam a identificar vulnerabilidades, avaliar riscos e proporcionam insights para o aprimoramento das medidas de segurança. Tanto as auditorias quanto as avaliações desempenham um papel vital na manutenção da conformidade, na mitigação de riscos e na melhoria contínua da segurança geral e do desempenho operacional de uma organização.

Objetivos abordados no exame:

- 5.5 Explicar os tipos e finalidades das auditorias e avaliações.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Atestação refere-se à verificação e validação da precisão, confiabilidade e eficácia dos controles, sistemas e processos de segurança implementados em uma organização. Envolve um exame independente e objetivo por uma entidade qualificada e confiável, como um auditor ou avaliador. O atestado é uma declaração ou confirmação formal de que os controles e práticas de segurança de uma organização estão em conformidade com padrões, regulamentos ou práticas recomendadas específicas e proporciona uma garantia às partes interessadas, como à gerência, aos clientes e aos

parceiros de negócios e reguladores, de que as medidas de segurança de uma organização são adequadas e eficazes à proteção de informações confidenciais, mitigação de riscos e manutenção da confidencialidade, integridade e disponibilidade dos dados.

Avaliações internas e externas

Usar métodos de auditoria e avaliação internos e externos é essencial para uma análise abrangente e eficaz dos sistemas, controles e processos de gerenciamento de uma organização. Os próprios funcionários da organização realizam auditorias internas e fornecem uma avaliação aprofundada dos processos de negócios da organização. As equipes internas podem realizar avaliações regulares e focadas que se alinham às necessidades e prioridades da organização e apoiam o monitoramento e a melhoria contínuos dos controles internos, das práticas de governança e gestão de riscos e da eficiência operacional.

Em contrapartida, prestadores de serviços terceirizados independentes realizam auditorias e avaliações externas que utilizam conhecimento e experiência especializados em domínios específicos, regulamentos e práticas recomendadas do setor. Os auditores externos transmitem uma avaliação imparcial e objetiva das práticas de negócios impossível de obter por parte das equipes internas. As auditorias externas garantem que as práticas da organização sejam medidas em relação aos padrões reconhecidos do setor e ajudam a identificar áreas de melhoria que podem ter passado despercebidas às equipes de auditoria internas.

As organizações podem atingir vários objetivos importantes utilizando métodos de auditoria e avaliação internos e externos. Usar ambas as abordagens ajuda a facilitar uma visão equilibrada e abrangente das práticas de gestão de riscos, controles e esforços de conformidade da organização. A combinação de auditorias internas e externas aumenta as competências de gestão de riscos da organização. As auditorias internas permitem o monitoramento contínuo, a detecção precoce de problemas e a correção em tempo hábil, enquanto as auditorias externas validam os controles, a conformidade e os esforços de mitigação de riscos da organização.

Além disso, a utilização de métodos internos e externos promove a transparência e a responsabilização. As auditorias internas promovem uma cultura de autoavaliação e melhoria contínua dentro da organização, enquanto as auditorias externas proporcionam às partes interessadas uma garantia e validação independentes a respeito das práticas da organização. Essa combinação ajuda a criar confiança entre as partes interessadas, incluindo clientes, parceiros de negócios, órgãos reguladores e investidores. Um benefício muitas vezes despercebido é que a colaboração entre auditores internos e externos facilita o compartilhamento de conhecimento e o desenvolvimento profissional, melhorando a qualidade das avaliações de ambas as equipes. Os auditores internos podem aprender com a experiência e as práticas recomendadas dos auditores externos, enquanto estes obtêm uma compreensão mais profunda do ambiente operacional da organização e dos desafios que ela enfrenta e que muitas vezes dificultam as iniciativas de conformidade.

Avaliações internas

Abordagem

Descrição

Abordagem	Descrição
Avaliação de conformidade	As avaliações internas de conformidade garantem que as práticas operacionais estejam alinhadas às leis, regulamentações, padrões, políticas e requisitos éticos. Essas avaliações julgam a eficácia dos controles internos, identificam áreas de não conformidade ou risco e comunicam as descobertas às partes interessadas, como os gerentes de risco.
Comitê de auditoria	Os comitês de auditoria proveem supervisão e garantia independentes quanto aos relatórios financeiros, controles internos e práticas de gestão de riscos de uma organização. Esses comitês são normalmente compostos por membros do conselho independentes da equipe de diretoria da organização. Os comitês de auditoria têm como objetivo reforçar a integridade dos demonstrativos financeiros, garantir a conformidade com os requisitos legais e regulamentares, monitorar a eficácia dos controles internos, supervisionar o processo de auditoria externa e promover a transparência e a responsabilização. Os comitês de auditoria são fundamentais para promover a confiança entre os acionistas, as partes interessadas e o público, fornecendo uma avaliação independente e objetiva das práticas financeiras da organização e contribuindo para uma governança corporativa sólida.
Autoavaliação	As autoavaliações permitem que indivíduos ou organizações avaliem seu desempenho, práticas e adesão aos critérios estabelecidos em relação a métricas e medidas predeterminadas. Elas ajudam a identificar pontos fortes, pontos fracos e áreas de melhoria, o que permite que indivíduos ou organizações tomem medidas proativas para aprimorar sua eficácia e resultados. As autoavaliações pressupõem a disponibilidade de pessoal interno com a experiência, o conhecimento e a compreensão da área avaliada necessários para realizá-las.

Nota:

Avaliações internas são necessárias para agências governamentais de acordo com o NIST RMF, PCI-DSS e outros.

Avaliações externas

Abordagem	Descrição
Regulamentar	As autoridades ou agências reguladoras realizam avaliações para garantir a conformidade com leis, regulamentações ou padrões específicos do setor. As avaliações regulatórias avaliam se as organizações cumprem os requisitos regulatórios obrigatórios e promovem uma cultura de conformidade. As avaliações regulatórias geralmente envolvem inspeções, auditorias ou revisões de processos, práticas e controles para verificar a conformidade, identificar deficiências e fazer cumprir as obrigações regulatórias. As avaliações regulatórias desempenham um papel crítico na salvaguarda dos interesses públicos, na proteção dos consumidores, na manutenção da integridade do mercado e na preservação dos padrões do setor. Elas ajudam a mitigar riscos, assegurar uma concorrência justa e aumentar a transparência e a responsabilidade nos setores regulamentados.

Abordagem	Descrição
Exame	Um exame externo geralmente consiste em uma avaliação independente e formal conduzida por partes externas, como auditores ou reguladores, para avaliar a precisão, confiabilidade e conformidade das demonstrações financeiras, processos, controles ou aspectos específicos das operações de uma organização. Os exames externos se concentram em verificar a precisão das informações e garantir a conformidade com as leis e regulamentações aplicáveis ou padrões do setor. Exemplos de exames externos incluem auditorias de demonstrações financeiras, auditorias de conformidade regulamentar e avaliações específicas de ambientes de controle.
Avaliação	Uma avaliação externa geralmente consiste em uma avaliação ampla conduzida por especialistas ou consultores externos para avaliar o desempenho geral, as práticas, as capacidades ou as áreas de foco específicas de uma organização. As avaliações externas podem abranger vários elementos, como estratégia, eficiência operacional, gestão de riscos, segurança cibernética ou práticas de conformidade. O objetivo é fornecer uma perspectiva objetiva e independente sobre os pontos fortes e fracos e as oportunidades de melhoria da organização.
Auditoria independente por terceiros	As auditorias independentes realizadas por terceiros fornecem avaliações objetivas e imparciais dos sistemas, controles, processos e conformidade de uma organização. A importância das auditorias independentes reside na capacidade de oferecer uma perspectiva externa, livre de quaisquer conflitos de interesse ou predisposições. As auditorias independentes inspiram confiança entre as partes interessadas (incluindo clientes, parceiros de negócios, órgãos reguladores e investidores), pois atestam o compromisso de uma organização com a qualidade, a conformidade e a boa governança. Elas também ajudam as organizações a demonstrar transparência, responsabilidade e cumprimento dos padrões e regulamentos do setor.

Nota:

As entidades externas podem incluir contadores públicos certificados (Certified Public Accountants, CPA), auditores externos, empresas de consultoria, órgãos reguladores ou agências de avaliação especializadas. A independência desses avaliadores externos garante imparcialidade e objetividade no processo de avaliação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Um Pentest — frequentemente chamado apenas de *pen test* — utiliza técnicas de hacking autorizadas para identificar vulnerabilidades exploráveis nos sistemas de segurança do alvo. O teste de penetração também é conhecido como *hacking ético*. Um teste de penetração pode envolver as seguintes etapas:

- **Verificação da Existência de uma Ameaça:** Em cibersegurança, uma ameaça, como uma vulnerabilidade em um sistema ou rede, pode abranger qualquer elemento capaz de provocar uma ação ou evento negativo em um sistema, rede ou aplicação. O uso de técnicas de vigilância, engenharia social, scanners de rede e ferramentas de avaliação de vulnerabilidades pode ser empregado para identificar um vetor pelo qual vulnerabilidades possam ser exploradas.
- **Contornar os controles de segurança:** procurar maneiras fáceis de atacar o sistema. Por exemplo, se a rede é fortemente protegida por um firewall, é possível obter acesso físico a um computador no prédio e executar malware a partir de um pendrive?
- **Testar ativamente os controles de segurança:** investigar os controles procurando por fraquezas e erros de configuração, como senhas fracas ou vulnerabilidades de software.
- **Explorar vulnerabilidades: provar que uma vulnerabilidade é de alto risco explorando:** a para obter acesso a dados ou instalar backdoors.

A principal diferença em relação à avaliação de vulnerabilidade passiva é que é feita uma tentativa de testar ativamente os controles de segurança e explorar quaisquer vulnerabilidades descobertas. O teste de penetração é uma técnica de avaliação intrusiva. Por exemplo, a varredura de vulnerabilidade pode revelar que um servidor de SQL não foi corrigido para proteger contra uma exploração conhecida. O teste de penetração tentaria usar a exploração para executar uma injeção de código e comprometer o servidor. Isso promove testes ativos de controles de segurança.

Reconhecimento ativo e passivo

A sondagem ativa e passiva fornecem informações cruciais que ajudam os testadores de penetração a entender os sistemas-alvo e a identificar possíveis vulnerabilidades para planejar um ataque de forma eficaz. Uma combinação de técnicas de sondagem ativa e passiva produz informações mais abrangentes sobre o ambiente-alvo durante a ocorrência de um teste de penetração.

[[Reconhecimento ativo]] envolve a sondagem e interação ativa com sistemas e redes-alvo para coletar informações. A sondagem ativa inclui atividades que geram tráfego de rede ao solicitar diretamente informações dos sistemas-alvo. Visa descobrir e obter informações sobre a infraestrutura, os serviços e as vulnerabilidades potenciais do alvo. Técnicas comumente usadas na sondagem ativa incluem:

- **Varredura de portas (Port Scanning):** varredura de uma rede-alvo para identificar portas abertas e os serviços em execução nelas.
- **Enumeração de serviços (Service Enumeration):** interação com os serviços identificados para coletar informações sobre suas versões, configurações e possíveis vulnerabilidades.
- **Fingerprint do SO (OS Fingerprinting):** tentativa de identificar o sistema operacional em execução nas máquinas-alvo através da análise das respostas e do comportamento da rede.
- **Enumeração de DNS:** coleta de informações sobre a infraestrutura de DNS do alvo, como nomes de domínio, subdomínios e endereços IP.
- **Rastreamento de aplicativos da Web (Web Application Crawling):** exploração de aplicativos da Web para identificar páginas, diretórios e possíveis vulnerabilidades.

[[Reconhecimento passivo]] consiste em coletar informações sobre sistemas e redes-alvo sem interagir diretamente com eles, concentrando-se na obtenção de dados publicamente disponíveis e na observação passiva do tráfego de rede.

Técnicas comumente usadas na sondagem passiva incluem:

- **Levantamento de inteligência de código aberto (Open-Source Intelligence, OSINT):** coleta de informações disponíveis publicamente de várias fontes, como mecanismos de busca, mídias sociais, bancos de dados públicos e sites.
- **Análise de tráfego de rede:** monitoramento do tráfego de rede para identificar padrões, dispositivos, endereços IP e possíveis vulnerabilidades sem gerar tráfego ativamente.

A sondagem passiva ajuda os testadores de penetração a coletar informações iniciais sobre a pegada digital de um alvo.

É menos intrusiva e carrega um risco de detecção menor do que as técnicas de sondagem ativa.

Métodos de teste em ambiente conhecido, parcialmente conhecido e desconhecido

A decisão de usar um teste de penetração em ambiente conhecido, ambiente parcialmente conhecido ou ambiente desconhecido é influenciada por vários fatores, como o conhecimento sobre o sistema ou rede-alvo, o apetite ao risco da organização e os requisitos de conformidade. Restrições de orçamento e recursos também podem contribuir para a seleção do método de teste de penetração, pois a aplicação dele em um ambiente conhecido geralmente requer menos recursos do que os testes em um ambiente parcialmente conhecido ou desconhecido. Os objetivos do teste de penetração influenciam a escolha: os testes em um ambiente conhecido são adequados para avaliar vulnerabilidades conhecidas, e os testes em um ambiente parcialmente conhecido ou desconhecido são preferíveis para identificar vulnerabilidades desconhecidas. A complexidade do sistema ou rede alvo também é um fator, pois sistemas mais complexos podem exigir métodos de teste mais abrangentes. As organizações geralmente combinam métodos diferentes para atingir objetivos diferentes.

Método de teste de penetração	Descrição
Teste de penetração em ambiente conhecido	Nos testes de penetração em um ambiente conhecido, o testador tem conhecimento detalhado sobre o sistema ou rede alvo, incluindo informações sobre a arquitetura de rede, configurações de hardware e software, vulnerabilidades do sistema e usuários.
Teste de penetração em ambiente parcialmente conhecido	Nos testes de penetração em um ambiente parcialmente conhecido, o testador tem conhecimento limitado sobre o sistema ou rede alvo, como informações sobre a arquitetura do sistema, tecnologias específicas em uso ou configurações parciais do sistema. Durante um teste de penetração em ambiente parcialmente conhecido, o testador pode empregar técnicas de reconhecimento para coletar informações adicionais sobre o alvo, incluindo uma varredura da rede, serviços de impressão digital ou coleta de inteligência de código aberto (OSINT). As informações coletadas são usadas para avaliar os controles de segurança, simulando vetores de ataque e explorando vulnerabilidades.

Método de teste de penetração

Descrição

Teste de penetração em ambiente desconhecido

Nos testes de penetração em um ambiente desconhecido, o testador tem pouco conhecimento prévio sobre o sistema ou rede alvo. Esse tipo de teste visa imitar um cenário em que um invasor não possui informações preexistentes sobre a infraestrutura do alvo. O objetivo é identificar possíveis vulnerabilidades e avaliar a capacidade da organização de resistir a um ataque de um adversário desconhecido. Durante um teste de penetração em ambiente desconhecido, o testador deve realizar um amplo reconhecimento para obter conhecimento sobre o alvo, como coleta passiva de informações, varredura ativa, engenharia social e outras técnicas para descobrir possíveis vulnerabilidades. O objetivo é identificar fragilidades que podem ser exploradas por um invasor habilidoso.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O teste de penetração é um componente crucial das avaliações de segurança cibernética que envolve simular ataques reais a sistemas, redes ou aplicativos de computador para identificar vulnerabilidades e fragilidades. Existem diferentes tipos de testes de penetração para abordar objetivos específicos relacionados a uma avaliação de segurança, como testar sistemas específicos, avaliar as capacidades de resposta a incidentes, medir a eficácia dos controles físicos e muitas outras áreas. Diferentes tipos de Pentest permitem que as organizações adotem uma abordagem flexível e priorizada para avaliações de segurança.

Teste de penetração ofensiva e defensiva

O [[Pentest ofensivo]], frequentemente chamado de "Red Teaming", é uma abordagem proativa e controlada para simular ataques cibernéticos reais contra os sistemas, redes e aplicativos de uma organização. O principal objetivo dos testes de penetração ofensiva é identificar vulnerabilidades, fragilidades e possíveis vetores de ataque que agentes mal-intencionados possam explorar. Esse teste geralmente é realizado por profissionais de segurança cibernética qualificados e éticos que imitam as táticas, técnicas e procedimentos (TTPs) de possíveis invasores.

O [[Pentest defensivo]], ou "Blue Teaming", avalia as medidas de segurança defensivas da organização, as capacidades de detecção, os procedimentos de resposta a incidentes e a resiliência geral diante de ameaças cibernéticas. Esse tipo de teste visa avaliar a eficácia dos controles de segurança existentes e identificar áreas de melhoria.

Testes de penetração física

O [[Pentest físico]], ou teste de segurança física, refere-se à avaliação das práticas e controles de segurança física de uma organização. Consiste em simular cenários de ataque real para identificar vulnerabilidades e fragilidades em sistemas de segurança física, como controles de acesso, vigilância e defesas de perímetro. Esse tipo de teste visa avaliar a eficácia dos controles de segurança física e identificar possíveis pontos de entrada ou fragilidades que um invasor possa explorar. Durante o teste de penetração física, um testador qualificado tenta obter acesso físico não autorizado a áreas restritas, informações sensíveis ou ativos críticos dentro da organização usando técnicas como engenharia social, “caronas” para obter entrada não autorizada, arrombamento de fechaduras, contorno de alarmes ou sistemas de vigilância e exploração de vulnerabilidades físicas.

Testes de penetração integrados

O [[Pentest integrado]] refere-se a uma abordagem holística que combina diferentes metodologias e técnicas de Pentest para avaliar a segurança geral dos sistemas, redes, aplicativos e infraestrutura física de uma organização. O teste de penetração integrado visa fornecer uma avaliação abrangente e realista das operações de segurança de uma organização. A importância do teste de penetração integrado reside na sua capacidade de representar com precisão a postura de segurança da organização e identificar riscos potenciais frequentemente negligenciados ao fazer testes em áreas isoladas. Por exemplo, a combinação de testes de penetração ofensiva e defensiva fornece uma avaliação abrangente da postura de segurança de uma organização. Os testes ofensivos identificam vulnerabilidades e fragilidades, enquanto os testes defensivos avaliam a capacidade da organização de detectar e responder a ameaças. Ao integrar ambas as abordagens, as organizações podem melhorar seus recursos de segurança para se proteger melhor contra diferentes ameaças.

Nota:

Um conceito semelhante é chamado de teste de penetração contínuo; ele se concentra em vulnerabilidades técnicas e geralmente é configurado para aproveitar a automação, especialmente em ambientes CI/CD. Consulte o link a seguir para obter mais informações: <https://informer.io/resources/continuous-penetration-testing>
(<https://informer.io/resources/continuous-penetration-testing>).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de explicar o gerenciamento de riscos, a análise de impacto nos negócios e os processos e as métricas do planejamento de recuperação de desastres.

Diretrizes para o gerenciamento de riscos

Siga estas diretrizes para auxiliar a avaliação de gerenciamento de riscos:

- Identifique e avalie os riscos continuamente para acompanhar as mudanças nas práticas de negócios.
- Analise o risco usando métodos qualitativos e quantitativos para ajudar a priorizar os esforços de remediação e alocar recursos.
- Crie um registro de riscos para ajudar a gerenciar e rastrear os riscos, incluindo a equipe designada para resolvê-los.
- Inclua práticas de negócios do fornecedor no gerenciamento e avaliação de riscos.
- Identifique e analise os fornecedores incluídos na cadeia de suprimentos e garanta que eles tenham operações de segurança adequadas.
- Use vários métodos de auditoria e avaliação para medir a eficácia dos controles de segurança e o alinhamento da organização aos requisitos de conformidade legal e regulatória.



This content is only available on larger screen sizes. Please revisit this page on a larger device.****